

Portfolio 5: Auditing and Logging Architecture

Carl Rundkvist og Holger Pedersen

System context

- Clearly define system being audited
- Identify actors (students, Administrators, API users, services)
- Identify sensitive data types
- State realistic assumptions about risk

Systemet som bliver underlagt auditering er kort sagt et universitets undervisningsplatform. Platformen tilgås af forskellige brugere herunder studerende, undervisere, forskere, adjunkter, samt system administratorer og service-desk.

Undervisningsplatformen indeholder forskellige følsomme data. Der er tale om både personfølsomme data på studerende, undervisere og andre medarbejdere, såsom navn, adresse, alder og CPR-nummer. Derudover behandles karakterer, afleveringer og forskningsdata fra universitetets forskningsafdeling også på platformen.

Systemet logger forskellige 'events', eksempelvis når forskningsmateriale og student resources tilgås, samt karakterer og admin-data. Her logges handlingerne: view, create, modify og delete. Derudover logger systemet også 'authentication' af brugere, som tilgår systemet.

Systemet står overfor forskellige risici, da der kan findes motivation hos aktører for 'malicious behaviour'. Herunder: Spoofing, Tampering og Information disclosure, som er de største. Her er der tale om en motivation for at studerende kan ændre i karakterer, stjæle andre studerendes opgaver, lække kritiske oplysninger som er opbevaret i systemet osv.

Data lifecycle diagram - for specific data

- Map the lifecycle of data (create > modify > access > archive > delete)
- Identify which stages require logging
- Justify why certain stages are high risk
- Explain why deletion and modification require stronger auditing
- Recognise that read access can also require auditing

Audit events per lifecycle stage

Each event you think might need to be audited includes

- Who (identity)
- What (action)
- When (timestamp)
- Where (origin)
- Outcome (success/failure)
- Authorisation basis role or permission used)

Karakterer

Create:

Underviseren opretter karakterer for studerende på studieportalen.

- Kræver logging.
- Der er risiko for spoofing og tampering i denne del af livscyklussen, derfor er den høj risiko.
- Audit events: When, Where, Who, What, Outcome, Authorization role or permission use.

Modify:

Underviser modificere/retter karakterer for studerende på studieportalen. Efter godkendelse fra serviceadmin. Kun i tilfælde af fejl i karakter.

- Kræver logging.
- Der er risiko for spoofing og tampering i denne del af livscyklussen. Dog er sandsynligheden mindre end ved create trinnet, da dette kræver ekstern bekræftelse fra serviceadmin. Selvom dette trin er specielt udsat for motiverede angreb, har vi allerede ekstra sikkerhedsforanstaltninger, som mitigerer risikoen. Udover det er der høj risiko.
- Audit events: When, Where, Who, What, Outcome, Authorization role or permission use.

Access:

Underviser eller elev, tilgår karakterer på studieportalen. Karakteren læses af brugeren.

- Kræver logging
- Lav risiko i read only tilstand, dog er der risiko for spoofing f.eks. en elev tilgår en anden elevs karakterer. Samt information disclosure, ved ufrivillig offentliggørelse af karakterer, i sammenhæng med spoofing.
- Audit events: When, Where, Who, What.

Archive:

Karakteren gemmes i arkivdatabasen på studieportalen.

- Kræver logging
- Det er vigtigt at vide om et commit til en database er foregået korrekt, så derfor er der høj risiko.
- Audit events: When, Outcome

Delete:

Underviseren sletter karakter fra studieportalen ved fejl. Dette kræver ekstern godkendelse fra serviceadmin.

- Kræver logging
- Der er høj risiko for spoofing og tampering samt motivation for at udføre disse angreb. Ligesom modify kræver dette trin ekstern godkendelse for at underviser kan udføre det. Derfor er sandsynligheden for succesfulde angreb mindre, da ekstra sikkerhedsforanstaltninger er foretaget.
- Audit events: When, Where, Who, What, Outcome, Authorization role or permission use.

Forskningsmateriale**Create:**

Researcher opretter dokumenter og eller research data på studieportalen

- Kræver logging.
- Der er risiko for spoofing og tampering i denne del af livscyklussen, derfor er den høj risiko.
- Audit events: When, Where, Who, What, Outcome, Authorization role or permission use.

Modify:

Researcher modificere/retter research data på studieportalen. Efter godkendelse fra serviceadmin. Kun i tilfælde af fejl i research data.

- Kræver logging.
- Der er risiko for spoofing og tampering i denne del af livscyklussen. Dog er sandsynligheden mindre end ved create trinnet, da dette kræver ekstern bekræftelse fra serviceadmin. Selvom dette trin er specielt udsat for motiverede angreb, har vi allerede ekstra sikkerhedsforanstaltninger, som mitigere risikoen. Udover det er der høj risiko.
- Audit events: When, Where, Who, What, Outcome, Authorization role or permission use.

Access:

Researcher eller elev+, tilgår research data på studieportalen. Research dataen læses af brugeren.

- Kræver logging
- Lav risiko i read only tilstand, dog er der risiko for spoofing f.eks. en elev tilgår dataen udklædt som en anden elev og lækker detaljer på f.eks nettet(information disclosure).
- Audit events: When, Where, Who, What.

Archive:

Karakteren gemmes i arkivdatabasen på studieportalen.

- Kræver logging
- Det er vigtigt at vide om et commit til en database er foregået korrekt, så derfor er der høj risiko.
- Audit events: When, Outcome

Delete:

Researcher sletter research data fra studieportalen ved fejl. Dette kræver ekstern godkendelse fra serviceadmin.

- Kræver logging
- Der er høj risiko for spoofing og tampering samt motivation for at udføre disse angreb.
- Audit events: When, Where, Who, What, Outcome, Authorization role or permission use.

Layered audit architecture diagram - each layer with relevant events

System-Level Audit Trails:

Logging af log-on's og -off's foretaget af alle brugere på platformen.

Application-Level Audit Trails:

Logging af handlinger udført på platformen. View, create og editing af data på platformen. Herunder karaktere, og forskelligt materiale.

Her logges også download og export af disse data.

Dette er ikke ændringerne i data som logges.

Database-Level Audit Trails:

Logging af ændringer i data. Dette gøres for at mitigere, at integriteten af data kompromitteres.

Network-Level Audit Trails:

Logging af netværkstrafik, såsom IP adresser der tilgår systemet.

User Activity Audit Trails:

Logging af brugeres aktivitet og handlinger på platformen.

Access control to audit data - How will access be managed?

Log protection strategy - stopping logs being impaired

System admin rollen er den eneste rolle der skal have adgang til logs. Der vil implementeres en append only policy som betyder at man ikke kan redigere i logs, men kun tilføje til dem. Dermed undgår man tampering. Logs skal krypteres fordi der er risiko for at de indeholder sensitiv information. For at sikre os integriteten på logs vil vi sammenligne hashes. Vi vil gøre brug af en SIEM for at centralisere vores logs og gøre det svært for ondsindede aktører at tilgå dem. Der skal tages backup af logs inkrementel hver dag, og en fuld backup hver uge.

STRIDE mapping (Tampering & Repudiation)

Vi forstår ikke opgaven..